

API Security Risk Analysis Report

1. Introduction

This report presents an API Security Risk Analysis conducted on a public demo API to identify common security vulnerabilities. The purpose of this analysis is to evaluate authentication, authorization, and data exposure controls using ethical and non-intrusive testing techniques. The assessment helps understand potential security risks and recommend mitigation strategies.

2. Tools Used

- Postman
 - Browser Developer Tools
 - Public Demo API (JSONPlaceholder)
 - MS Word / Google Docs
-

3. API Overview

- **API Name:** JSONPlaceholder
 - **Base URL:** <https://jsonplaceholder.typicode.com>
 - **Tested Endpoint:** /users
 - **HTTP Method:** GET
 - **Authentication Required:** No
-

4. Identified Security Risks

Risk 1: Unauthenticated Access

Description: The API allows access to user information without requiring any form of authentication or authorization.

Impact: Unauthorized users can retrieve user data, which may lead to data leakage and privacy concerns.

Severity: Medium

Recommendation: Implement authentication mechanisms such as API keys or JWT-based authentication to restrict access.

Evidence: Screenshot: 01_unauthenticated_access_users.png

Risk 2: Excessive Data Exposure

Description: The API response exposes sensitive user details such as email address, phone number, physical address, and geo-location data.

Impact: Exposure of sensitive data can result in privacy violations and misuse of personal information.

Severity: High

Recommendation: Limit the data returned by the API and mask or remove sensitive fields from responses.

Evidence: Screenshot: 01_unauthenticated_access_users.png

Risk 3: Broken Object Level Authorization (BOLA)

Description: The API allows access to individual user records by modifying the user ID in the endpoint URL without verifying user permissions.

Impact: Attackers can enumerate and access other users' data, leading to unauthorized data access.

Severity: High

Recommendation: Enforce proper authorization checks to ensure users can only access permitted resources. Implement role-based access control.

Evidence: Screenshots: - 02_broken_authorization_user_1.png - 03_broken_authorization_user_2.png

5. Impact Analysis

The identified vulnerabilities expose the API to risks such as unauthorized data access, privacy breaches, and potential misuse of sensitive information. If exploited, these issues could negatively affect user trust and system security.

6. Remediation Suggestions

- Implement strong authentication and authorization mechanisms.
 - Apply role-based access control for API endpoints.
 - Reduce sensitive data exposure in API responses.
 - Enforce rate limiting and input validation.
-

7. Conclusion

The API Security Risk Analysis revealed multiple security weaknesses related to authentication, authorization, and data exposure. Addressing these vulnerabilities by implementing recommended security controls will significantly enhance the security posture of the API.

End of Report